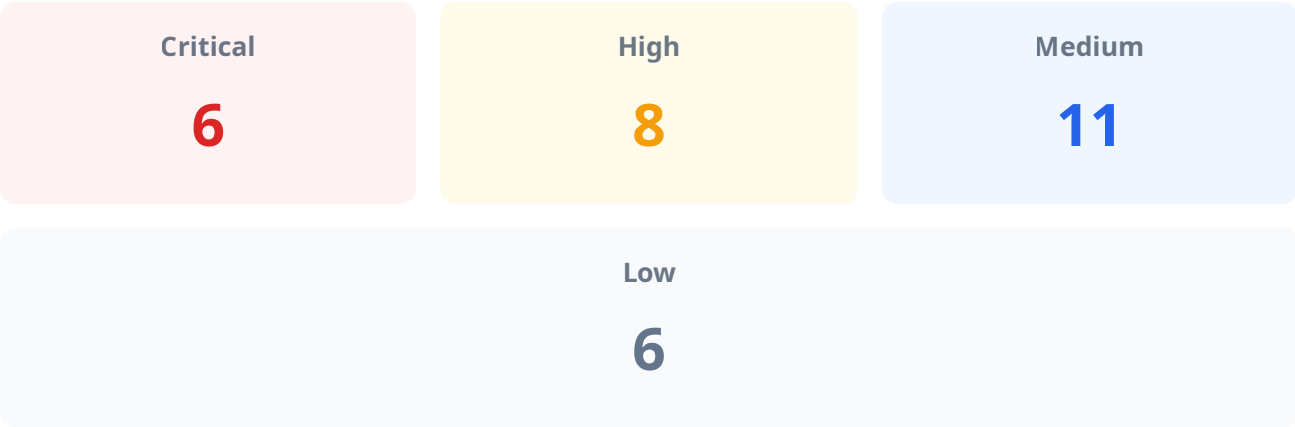


FishMarket Platform — Audit Report

Comprehensive architecture, security & feature audit | July 4, 2026

1. Executive Summary

The FishMarket platform consists of **5 frontend apps** (customer web, admin dashboard, seller dashboard, driver mobile, marketing website) and a **NestJS monolith API** backed by PostgreSQL via Prisma. The codebase is well-structured with consistent patterns, but has several critical gaps — most notably **no real payment integration, no customer communication after ordering, no SEO on the customer-facing site, and no tests on the core order/delivery state machines.**



2. Architecture Overview

App	Stack	Purpose
apps/web	Next.js 15, React 19, Tailwind	Customer-facing marketplace
apps/admin	Vite 6, React 18, React Router 7	Admin dashboard
apps/api	NestJS, Prisma, PostgreSQL, Redis	REST API monolith
apps/mobile	React Native	Driver mobile app
apps/seller	Vite + React 18	Seller dashboard

packages/shared	TypeScript	Shared types & utils
packages/ui	React + Tailwind	Shared UI components

3. Critical Issues

3.1 No Real Payment Integration CRITICAL

The payment system has a pluggable provider registry (Stripe, Bank Transfer, Cash on Delivery), but **all providers are mock/placeholder implementations**. Orders cannot be paid. The only way to move an order from DRAFT to CONFIRMED is through manual admin intervention. This blocks the entire revenue model.

3.2 No Order Confirmation Communication CRITICAL

EmailNotificationChannel exists but is not implemented. Only in-app database notifications work. After a customer places an order, **they receive zero communication** — no email, no SMS. They cannot track their order status without calling the store.

3.3 No SEO on Customer-Facing Web App CRITICAL

The web app has:

- No metadata exports on any page
- No Open Graph tags
- No JSON-LD structured data
- No sitemap or robots.txt
- Hardcoded `<html lang="en">` that never follows the user's locale selection
- All pages are 'use client' — no server components, no SSR for SEO

3.4 No Token Refresh in Admin App CRITICAL

`auth.service.ts` has a `refreshToken()` method, but the 401 axios interceptor **destroys the session instead of attempting a refresh**. After the JWT expires (default 15 minutes), every admin gets logged out mid-session with no warning.

3.5 JWT in localStorage (XSS-Vulnerable) CRITICAL

Both admin and seller apps store JWT tokens in `localStorage`. Any XSS vulnerability exposes all user tokens. `httpOnly` cookies would be significantly more secure.

3.6 No Tests on Core Business Logic CRITICAL

Zero test files across the entire admin app and web app. The API has no test files either. The order and delivery state machines contain the most complex business logic in the platform — status transitions, inventory reservation, financial calculations — all untested.

4. High-Priority Issues

4.1 Admin Dashboard is a Placeholder HIGH

4 stat cards + a recent orders list. The revenue card literally says "Coming soon". No charts, no trends, no KPIs. recharts is installed but unused.

4.2 No Edit Routes for Key Entities HIGH

Listings detail is read-only. Payments and Deliveries have no detail page. Users have no edit page. Store owner cannot be reassigned after creation.

4.3 Forms Use Raw `useState` Despite Having `react-hook-form` + `zod` Installed HIGH

All 20+ admin forms use ad-hoc validation with `useState`. Some use `HTML required`, some use custom `validate()` functions, some just `if (!x) return`. No consistent pattern. The form libraries are already in `package.json` — they just need to be used.

4.4 No Customer Order Tracking HIGH

Guest checkout creates a random anonymous user. There is no order tracking page, no way for customers to check their order status without calling the store or the admin.

4.5 Delivery Fee Hardcoded at 0 HIGH

The delivery-fee module supports `FLAT`, `DISTANCE_BASED`, and `ZONE_BASED` strategies, but the default is 0. No delivery fee is ever charged.

4.6 Web App Uses Raw `fetch()` — No Caching HIGH

All API calls use raw `fetch()` with no caching, no deduplication, no stale-while-revalidate. Every navigation re-fetches the same data. No React Query, no SWR, no request cancellation.

4.7 No Image Optimization HIGH

Every image in the web app uses plain `<img>` tags. No `next/image`, no WebP conversion, no lazy loading, no responsive image sizes.

4.8 Type Duplication Across Apps HIGH

`apps/web/src/lib/types.ts` redefines types (`FishCategory`, `Listing`, `CartItem`) that already exist in `@fishmarket/shared`. These will inevitably drift over time.

5. Order Flow Analysis

Current Flow

```
Cart → Checkout (guest) → Order DRAFT
  → (admin manual) → PENDING → CONFIRMED → PREPARING
  → READY_FOR_PICKUP → (driver assigned) → OUT_FOR_DELIVERY → DELIVERED
```

Strengths

- Immutable OrderStatusHistory append-only audit trail
- Prisma transactions for atomic inventory reservation + order creation
- Multi-seller order splits (parent + child orders per seller)
- Event-driven notifications and job scheduling (Bull + Redis)
- State machine validation preventing illegal transitions server-side

Gaps

- **No payment gateway** — the entire CONFIRMED → revenue flow is blocked
- **No customer communication** after order placement (email/SMS)
- **No order tracking page** for customers
- **Delivery fee is always 0**
- **No inventory replenishment workflow** for sellers
- **Expiration timeout not configurable via UI** despite PlatformConfig model existing

6. Security Audit

Area	Status	Risk
Password hashing	bcrypt, 12 rounds	OK
JWT secret	Configurable via environment	OK
CORS	Whitelist of allowed origins	OK
Helmet security headers	Installed, CSP disabled	REVIEW

Rate limiting	300 req/min global (ThrottlerGuard)	OK
Input validation	Prisma ORM + ValidationPipe (whitelist)	OK
Auth on admin routes	JwtAuthGuard + RolesGuard + PermissionsGuard	OK
Token refresh	Implemented but NOT wired in admin app	FAIL
JWT storage	localStorage (XSS-vulnerable)	FAIL
CSRF protection	Not visible	REVIEW
SQL injection	Parameterized queries via Prisma	OK
Soft delete	Implemented on User model	OK

7. Recommended Roadmap

Immediate (Week 1-2)

#	Issue	Impact
1	Wire token refresh in admin app	Prevents random session drops
2	Add SEO metadata + Open Graph to web app	Critical for organic discoverability
3	Remove dead code (listing-card.tsx, providers.tsx, products.service.ts, commented-out blocks, unused deps)	Reduces maintenance burden
4	Fix <html lang> to follow locale selection	Accessibility + i18n correctness
5	Add loading skeleton to driver audit logs	UX polish

Short-term (Month 1)

#	Issue	Impact
6	Implement one real payment provider (Cash on Delivery or Stripe)	Unblocks revenue flow
7	Add react-hook-form + zod to all admin forms (already installed)	Consistent validation
8	Add React Query to web app for data fetching	Caching, dedup, faster UX
9	Add analytics (Plausible or PostHog) to web app	Business metrics
10	Implement email/SMS notification for order confirmation	Customer communication
11	Build a real dashboard with recharts	Admin decision-making
12	Add edit routes for listings, users, delivery detail	Admin functionality

Medium-term (Quarter 1-2)

#	Issue	Impact
13	Customer order tracking page (/orders/: token)	Customer experience
14	Bulk actions on admin tables (multi-select, batch status)	Admin efficiency
15	Sorting + CSV export on data tables	Admin efficiency
16	Configure delivery fee (distance or zone-based)	Revenue + cost coverage
17	Unit tests for order/delivery state machines	Risk reduction
18	Accessibility: focus management, aria labels, skip-to-content	Compliance + UX
19	Adopt shared types from @fishmarket/shared	Type consistency

Long-term (Quarter 2+)

#	Issue	Impact
20	Move JWT to httpOnly cookies	Security
21	Server components in web app	SEO + performance
22	Notification preferences UI (email/SMS/in-app)	User control
23	Inventory alerts for sellers (low stock, missing daily listing)	Seller experience
24	API versioning strategy	Future-proofing
25	Sitemap + robots.txt	SEO
26	PWA support (manifest, service worker)	Mobile UX

8. Dead Code & Technical Debt

File	Issue
apps/admin/src/services/products.service.ts	Defined but never imported anywhere
apps/admin/src/services/contants/index.ts	Typo CUST0LER, never imported
apps/web/src/components/listing-card.tsx	Defined but never imported
apps/web/src/components/providers.tsx	Defined but never imported
apps/web/src/components/sidebar.tsx ~40 lines	Commented-out decorative code
react-hook-form, zod, @hookform/resolvers (admin)	In package.json, never imported in any file
recharts (admin)	In package.json, never imported
zod (web)	In package.json, never imported
All any type annotations	~30+ occurrences across admin app; suppresses type checking
unwrap() misuse in users.service.ts	Calls unwrap<User>(data) but data is already unwrapped

9. Current Strengths

- **Consistent service pattern** across all 15 admin API clients
- **Feature-based directory structure** in both apps — easy to navigate
- **State machine validation** for orders and deliveries (server-enforced)
- **Prisma transaction atomicity** for critical paths (order creation, payment confirmation)
- **Event-driven architecture** decoupling order processing from notifications
- **Immutable audit trails** for all order/delivery status transitions
- **Double-entry wallet accounting** with balanceBefore/balanceAfter on every transaction
- **i18n with RTL support** (Arabic) in the web app
- **URL-driven filtering** making category/condition selections shareable

- **Image fallbacks** (Lucide icons) in every component
- **Empty states** on all lists and collections
- **Responsive design** with Tailwind breakpoints throughout
- **Pluggable payment provider registry** — adding real gateways is straightforward
- **Pluggable assignment strategies** for driver delivery assignment

10. Appendix: Complete Module Inventory (API)

Module	Files	Purpose
prisma	2	Prisma client connection (Global)
redis	2	Redis client (Global)
cache	2	Cache-aside with getOrSet (Global)
jobs	4	Bull queues: order expiration + notifications
events	1	EventEmitter configuration
auth	8	Register, login, JWT, refresh, password reset
users	-	User CRUD
addresses	-	Address management
sellers	9	Seller profiles, applications, admin management
drivers	9	Driver profiles, status, admin + audit
user-settings	-	User preferences
categories	5	Fish category hierarchy (self-referencing)
products	7	Master product catalog + variants
listings	7	Daily per-seller listings + admin oversight
marketplace	5	Public browsing + guest checkout
cart	5	Shopping cart operations
orders	12	Order CRUD, state machine, inventory, calculation

seller-orders	3	Seller order views + mark-ready
admin-orders	3	Admin order oversight + driver assignment
deliveries	13	Full delivery lifecycle
delivery-zones	4	Geographic zones with optional GeoJSON
delivery-fee	3	Fee calculation strategies
payments	14	Payment lifecycle with provider abstraction
wallet	5	Double-entry wallet
commission	3	Commission calculation strategies
billing	3	Receipts and settlement statements
notifications	15	In-app notifications + event handlers
audit-log	-	Compliance audit trail
cloudinary	-	Image upload integration
files	-	File storage abstraction
health	-	Health check endpoint
analytics	-	Analytics queries